

Voici un tableau présentant l'article 25 et ses principes : le Privacy by Design et le Privacy by Default. Le tableau présente également plusieurs notions importantes sur les données personnelles et son encadrement par le RGPD. On évoque ci-dessous 4 points : les données personnelles, la collecte des données, le traitement et le stockage des données. Ces 4 points sont présents dans les 2 colonnes du tableau, correspondant au Privacy by design et au Privacy by Default. Nous avons évoqué pour chaque point un article du RGPD pour justifier son appartenance au Privacy by Design ou au Privacy by Default.

Les responsables des données évoqués dans le tableau peuvent-être des entreprises, des organisations ou encore des responsables de sites web, de logiciels etc.

Article 25

L'article 25 dit que les responsables des données personnelles doivent prendre en compte la protection des données dès la conception de leurs sites web, logiciels etc. (c'est le Privacy by Design). Il oblige aussi à limiter (par défaut) la collecte et l'utilisation des données personnelles (c'est le Privacy by Default).

Quand une entreprise créer une application ou un site qui utilise des données personnelles, elle doit intégrer des protections dès le départ plutôt que d'ajouter des sécurités plus tard. Par exemple, on peut parler de chiffrement ou encore de limiter l'accès aux données et éviter de collecter plus d'informations qu'elle n'en a besoin.

Cet article demande que par défaut, seules les données essentielles soient utilisées. Ainsi, l'objectif de cet article est d'éviter tout risques pour les utilisateurs. Ceci en sécurisant les données dès le début et en s'assurant qu'elles ne sont utilisées que lorsque les responsables des données personnelles en ont besoin.

Privacy By Design

Le Privacy by Design désigne le fait que la protection des données doit être prévue dès la création d'un service, d'un site ou d'une application. Les mesures de sécurité doivent être mise en place dès le début pour éviter tout risque.

Privacy by Default

Le Privacy by Default désigne le fait que (par défaut) seules les données nécessaires vont être collectées et utilisées. L'utilisateur ne doit pas avoir à modifier les paramètres pour protéger ses données. Les responsables de données personnelles sécurisent tout dès le début.

Données personnelles (classiques et sensibles)

Article 9 : Traitement portant sur des catégories particulières de données à caractère personnel

Cet article est divisé en 2 paragraphes. Le premier explique que les données qui révèlent l'origine ethnique, les opinions politiques, les convictions religieuses ou philosophiques, l'appartenance syndicale, et les données génétiques ou biométriques sont considérées comme sensibles et leur traitement est interdit, sauf exceptions précisés dans le paragraphe 2 (par exemple le "consentement explicite", ou encore la "nécessité médicale").

Cet article permet de protéger les données personnelles sensibles. Ces données peuvent être utilisées à des fins discriminatoires par exemple. En effet, il est expliqué dans l'article que ces données sont interdites à des fins d'identification d'une personne. Le traitement est donc encadré par le RGPD et ne peut se faire que dans des cas précis. Ces cas sont listés dans le deuxième paragraphe en plusieurs points (10 points au total).

L'article 9 fait partie du Privacy by Design car il exige une protection renforcée dès la collecte des données sensibles.

Données personnelles (classiques et sensibles)

Article 35 : Analyse d'impact relative à la protection des données

IL est obligatoire lorsqu'un traitement de données peut engendrer un risque élevé pour les droits et libertés des personnes concernées.

Cet article anticipe les risques liés au traitement des données personnels. L'AIPD oblige les responsables de traitement à : Identifier les risques dès la conception d'un projet, mettre en place des mesures techniques et organisationnelles adéquates et à garantir que les paramètres de confidentialité sont définis au plus haut niveau par défaut. D'où son rapport avec le Privacy by default qui consiste à ce que par défaut seules les données strictement nécessaires doivent être collectées et traitées avec des garanties de sécurité maximales.

En résumé, l'article 35 s'inscrit donc dans la logique du Privacy by Default, en veillant à ce que la minimisation des données et la limitation de leur utilisation soient appliquées dès la phase de conception des traitements

Des mesures sont mises en place dès le début pour prévenir tout risque.	
Collecte des données Article 13 : Informations à fournir lorsque des données à caractère personnel sont collectées auprès de la personne concernée Cet article décrit que quand des données personnelles sont collectées, le responsable de la collecte doit informer la personne concernée sur plusieurs points : Qui est responsable des données, pourquoi elles sont collectées, qui y aura accès et si elles seront transférées à l'étranger. Cet article montre aussi la transparence dans la collecte des données. L'objectif est que les utilisateurs sachent exactement ce qui est fait de leurs informations. L'article 13 dit que les responsables de la collecte des données doivent donner des informations sur la collecte de données (qui collecte, pourquoi, etc.). Cela fait partie du Privacy by Design, car la transparence est intégrée dès le début. Les utilisateurs savent donc ce qui se passe avec leurs données.	Collecte des données Article 5 : Principes relatifs au traitement des données à caractère personnel Cet article établit les règles fondamentales qui encadrent la collecte des données personnelles. Il précise que toute collecte doit respecter plusieurs principes clés, notamment la licéité, la loyauté et la transparence, ainsi que la minimisation des données. L'article 5 garantit que les données collectées doivent être pertinentes, adéquates et limitées à ce qui est strictement nécessaire aux finalités du traitement. Cela empêche une collecte excessive ou injustifiée, assurant ainsi une meilleure protection des individus. Cet article a un rapport avec le Privacy by Default, car il impose à ce que, par défaut, seules les informations essentielles soient collectées. Il oblige les responsables de traitement à adopter des pratiques limitant la collecte aux stricts besoins opérationnels, réduisant ainsi les risques pour la vie privée.
Traitement des données Article 24 : Responsabilité du responsable du traitement L'article 24 stipule que les responsables des traitements de données doivent mettre en place des mesures adaptées pour respecter le RGPD. Elles doivent anticiper les risques et s'assurer que le traitement des données est légal. Cet article demande aux responsables du traitement des données de pouvoir anticiper dans la protection des données personnelles. Elles doivent prévoir à l'avance comment éviter les risques et non attendre qu'un risque survienne d'abord. Cet article fait partie du Privacy by Design car la protection des données est intégrée dès la conception. Il oblige aux responsables de réfléchir aux risques et aux solutions avant même de commencer à traiter les données.	Traitement des données Article 6 : Licéité du traitement Il définit les bases légales sur lesquelles un traitement de données personnelles peut être fondé. Il précise que tout traitement de données doit reposer sur l'une des six bases légales prévues, à savoir : le consentement de la personne concernée, l'exécution d'un contrat, le respect d'une obligation légale, la sauvegarde des intérêts vitaux, une mission d'intérêt public ou relevant de l'autorité publique, ou l'intérêt légitime du responsable du traitement. Cet article permet d'encadrer juridiquement le traitement des données en imposant des conditions précises pour garantir la protection des droits des individus. Il évite ainsi les abus et assure que les données ne sont pas traitées sans justification valable. L'article 6 a un rapport avec le Privacy by Design, car il impose aux organisations de définir, dès la conception d'un traitement, sa base légale et de s'assurer de sa conformité au RGPD. Cela implique une transparence renforcée et des mesures préventives pour éviter tout traitement illicite des données.

Stockage des données

Article 32 : Sécurité du traitement

L'article 32 définit que les responsables du stockage des données doivent prendre des mesures pour protéger les données. L'article évoque la "pseudonymisation" et le "chiffrement".

Ainsi, cet article oblige les responsables à mettre en place des protections adaptées aux risques et à tester régulièrement leur efficacité comme indiqué dans le paragraphe 1.d. par exemple.

Sachant que ces mesures de sécurité doivent être mises en place avant que les données ne soient stockées, cela correspond donc au Privacy by Design.

Stockage des données

Article 17 : Droit à l'effacement (« droit à l'oubli »)

L'article 17 du RGPD garantit aux personnes concernées le droit à l'effacement de leurs données personnelles lorsque celles-ci ne sont plus nécessaires aux finalités pour lesquelles elles ont été collectées.

Ce droit impose aux responsables de traitement de supprimer les données dans plusieurs cas, notamment :

Lorsque la personne retire son consentement, quand les données ne sont plus utiles, quand le stockage est contraire aux obligations légales et lorsqu'un traitement illicite est constaté

L'article 17 est directement lié au Privacy by Default, car il renforce le principe de minimisation du stockage. Par défaut, les données ne doivent pas être conservées indéfiniment et leur suppression doit être facilitée.